# Лабораторная работа. Сканеры уязвимостей уровня хоста.

В этой работе мы воспользуемся сканером уязвимостей ScanOVAL для оценки защищенности компьютера с операционной системой Windows и OpenSCAP для РедОС.

Аббревиатура OVAL расшифровывается как Open Vulnerability and Assessment Language. По сути это язык описания уязвимостей, описания на котором могут собираться в базы и использоваться программными продуктами для оценки защищенности. Спецификации опубликованы здесь https://oval.mitre.org/index.html, один из обзоров, например, здесь https://habr.com/ru/companies/pt/articles/139296/. обзор по сканерам безопасности https://habr.com/ru/articles/537974/

**Использование ScanOVAL для Windows**

С сайта разработчика https://bdu.fstec.ru/scanoval скачайте дистрибутив и базу уязвимостей. Выполните установку, ознакомьтесь с руководством пользователя https://bdu.fstec.ru/files/documents/scanoval_manual.pdf и запустите программу. Из главного меню откройте файл с базой уязвимостей и запустите сканирование. После окончания сканирования проверьте, что у вас отображаются только обнаруженные уязвимости (пример отчета на рис.1). Рассмотрите полученный список. Используя сортировку по уровню, найдите в списке критические уязвимости. Посмотрите, в каких программных продуктах они обнаружены. Сохраните отчет.

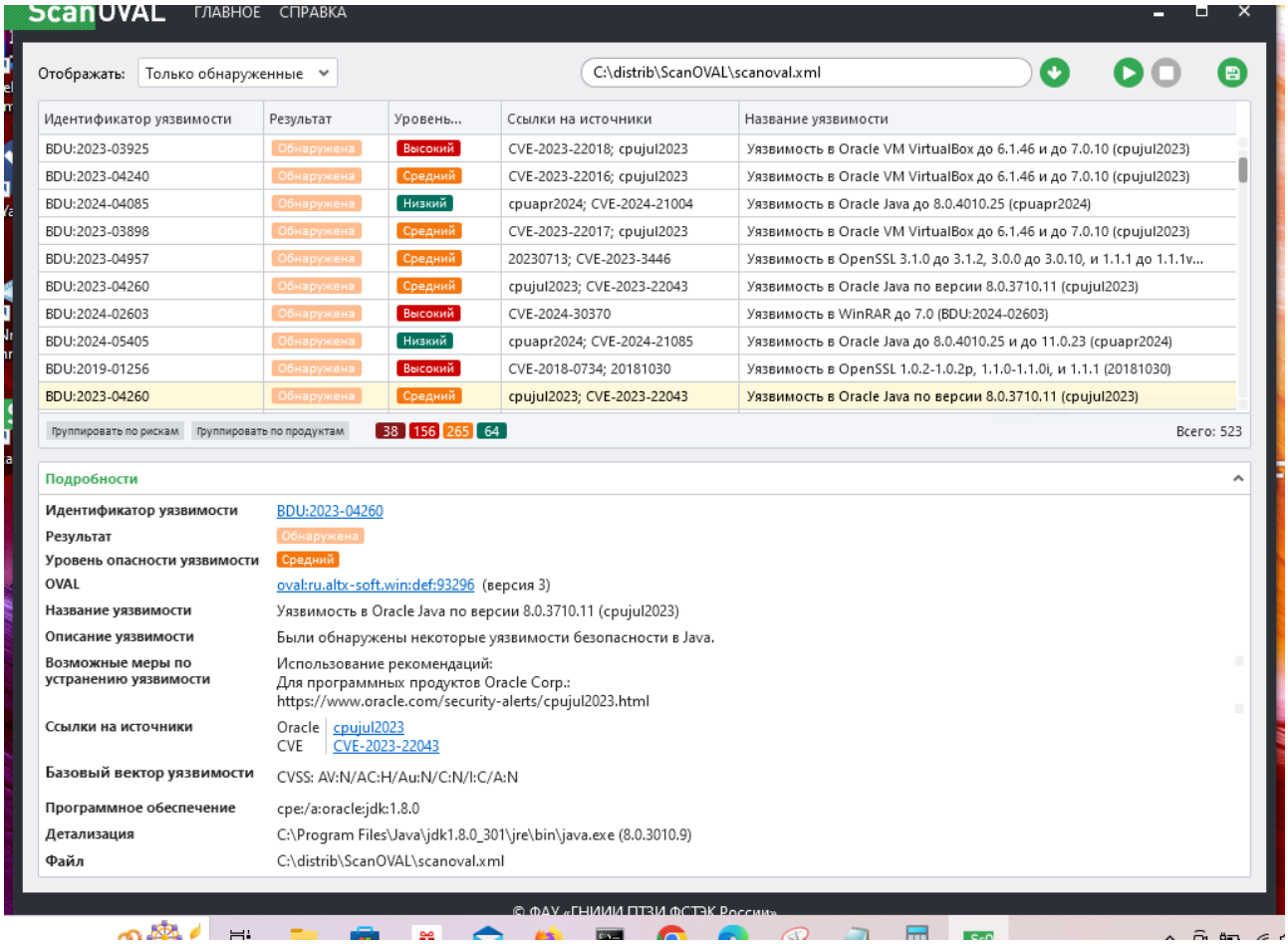


Рис.1 Пример результата сканирования

При наличии возможности, обновите какой-то из уязвимых программных продуктов до наиболее свежей версии, перед этим добавив в ваш отчет информацию о том, какие

уязвимости в нем были. Повторно выполните сканирование. Сравните результат с ранее полученным.

**Обнаружение уязвимостей в Ред ОС.**

В качестве сканера уязвимостей для РедОС разработчики этой операционной системы рекомендуют продукт OpenSCAP https://redos.red-soft.ru/base/manual/safe-redos/openscap/

Ознакомьтесь со статьей по ссылке.

Используя менеджер пакетов с интерфейсом командной строки dnf (как в статье) или графическую утилиту dnfdragora (Главное меню → Администрирование → Управление программами dnfgragora) установите пакеты openscap-scanner и openscap-utils (рис.2).

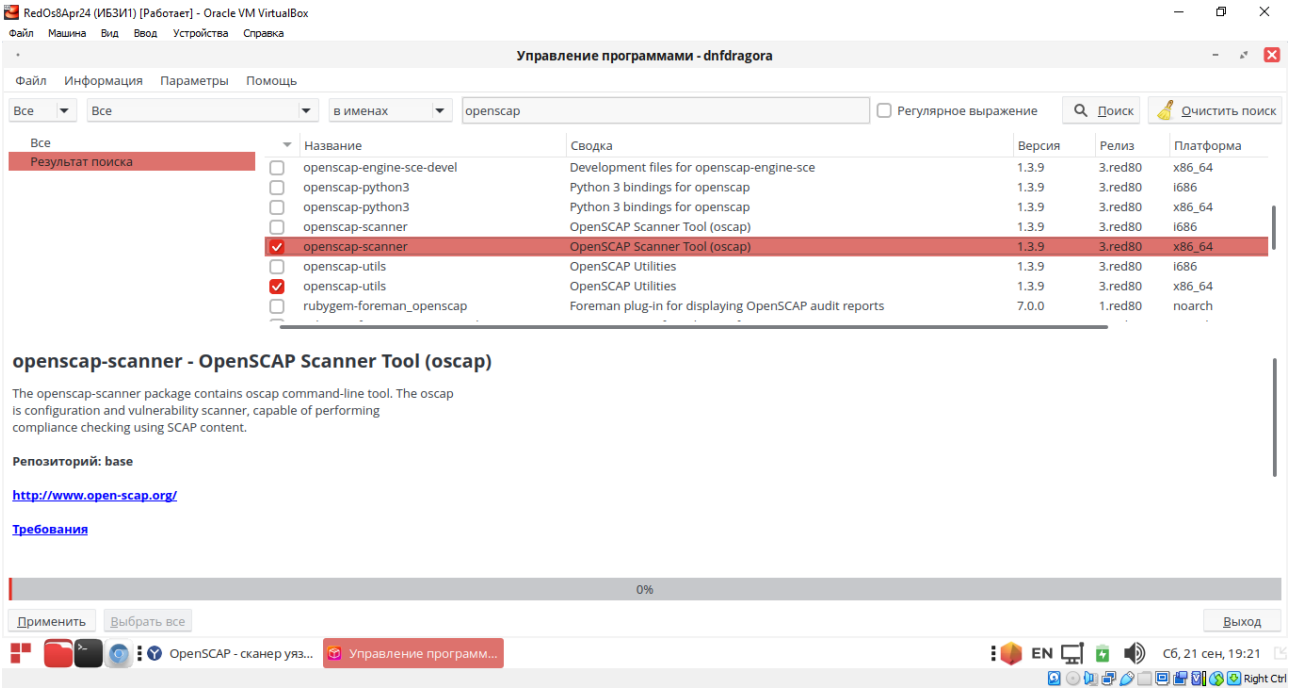



Рис.2 Установка OpenSCAP из dnfdragora

Командой

```
oscap --version
```

получите информацию о версии сканера и поддерживаемых платформах.

Далее скачиваем файл с описаниями уязвимостей под Ред ОС

```
wget https://redos.red-soft.ru/support/secure/redos.xml
```

Указав тип базы уязвимостей, название файлов для сохранения результатов сканирования и отчетов и файла с базой уязвимостей, запускаем сканирование

```
oscap oval eval --results results.xml --report report.html redos.xml
```

В домашнем каталоге текущего пользователя найдите файл с отчетом report.html и откройте его. В ваш отчет добавьте описание некоторых из обнаруженных уязвимостей (лучше взять те, для которых есть русскоязычные описания на сайте Ред ОС, например https://redos.red-soft.ru/support/secure/uyazvimosti/mnozhestvennye-uyazvimosti-chromium-17-09-24/ ).

Запустите уязвимое приложение (если речь идет о приложении с пользовательским интерфейсом, таком как Chromium, а не о службе), посмотрите его версию (для браузера Chromium это можно сделать из его меню, пункт О Chromium) и закройте. С помощью dnf или dnfdragora обновите соответствующие пакеты. Снова запустите приложение и проверьте версию. Повторите сканирование, сохранив результаты и отчет в другие файлы. Сравните новый отчет со старым.